



Production Readiness Report

Deep analysis from scratch — code, live production, security, release, operations — and the exact go-live runbook

25–26 September 2026 · updated after two fix rounds · app 1.0.3 (build 6) · website + API live on chillfi.in

READY* after the 6 owner steps	7 / 7 must-fix items done + deployed	6 owner switch-over steps
438/463 QA cases passing	124 defects found, all fixed	0 failing tests / JS errors

Update 26 Sep — every developer item in this report is now done, tested and deployed (section 0), including all 7 must-fix items, every "should fix soon" item, and a round of hardening found while doing that work (short staff sessions, hashed tokens/OTP codes, stricter input limits, an admin change-history log). What remains is only the owner's part: the 6 switch-over steps after client testing, the email domain, the Play upload of build 6, the uptime monitor and pushing the code. The original analysis (sections 1–25) follows unchanged for reference.

Original verdict (25 Sep, before fixes). The shop is built, tested and live on chillfi.in, and is safe to use for the client's testing right now (online payment is locked off, Delhivery is in test mode). It is **not yet ready for real customers: 7 developer fixes** (section 3) must land first — two of them would hurt real customers on day one (PhonePe return page shows "failed" after a successful payment; a test phone number can log in on production) — and then the owner performs the **6 switch-over steps** in the order given in section 4. Estimated developer effort for the must-fix list: about 1–1.5 working days, plus one real-device test session.

How to read this report: **Ready** = works now, verified. **Must fix** = developer change needed before real customers. **Owner step** = needs your account/keys/decision. **Verify** = could not be checked from outside the server; check once. **Recommended** = not a blocker.

0. Update — what was fixed after this analysis

0a. The 7 must-fix items (25 Sep)

#	Item	Status	Proof
F1	PhonePe return page	Fixed + live	Return URL carries the transaction id; "pending" shows "Payment processing" instead of "failed"; test: callback no longer "Missing transaction ID"
F2	Backend test login 9876543210	Fixed + live	Only when NODE_ENV=development (production server confirmed NODE_ENV=production)
F3	In-app account deletion	Verified (app build 6)	Settings › Delete account — tested end-to-end on the emulator (account removed, app returns to Welcome); staff accounts refused
F4	Firebase SHA fingerprints	Done	Corrected 26 Sep: 6 fingerprints registered in Firebase — debug keystore, upload key, and the Play App Signing key (the app had an earlier Play upload, so this was already available). Nothing left to add here; test real OTP on a real phone when convenient
F5	Website Delete Account	Fixed + live	Uses Firebase phone verification like Login; on chillfi.in it reaches Google reCAPTCHA (previously used a path that never sent SMS)
F6	Dependency advisories	Fixed + live	Backend 14 › 0 (nodemailer 10, send verified); website 2 moderate react-router advisories not reachable here (SSR / redirect path guarded)
F7	PhonePe webhook hardening	Fixed + live	Refused when keys missing; paid amount must match (tested: ₹1 "success" for a ₹799 order is not marked Paid)

0b. "Should fix soon" items from section 3 — now done

Item	Status	Proof
Voice search on Android 11+	Fixed + verified	Added the manifest <queries> entry; tested live on an Android 17 (API 36) emulator — tapping the mic opens the system speech recognizer ("Listening...") instead of failing silently
Unused biometric permission	Fixed (app build 6)	local_auth removed from pubspec — USE_BIOMETRIC/USE_FINGERPRINT no longer in the built manifest
Settings encryption key	Live	SETTINGS_ENCRYPTION_KEY generated and set on the server; a start-up migration re-encrypts any credential still under the old key, so nothing already saved was lost
Admin session	Enforced server-side	Staff (admin/support) access tokens now expire after 1 hour and refresh tokens after 12 hours, checked on the server — not just the 30-minute browser timer. Tested: a 2-hour-old admin token is rejected (401), customer sessions unchanged (7d/30d)
Rate-limit bypass (verify)	Tightened	OTP send/verify, Firebase verify, account deletion and coupon apply limited to 20/min per IP in production; contact form to 5/min. The plain-HTTP EC2 IP was also removed from the CORS allow-list
OTP generator	Fixed + live	crypto.randomInt instead of Math.random; codes are now stored hashed and compared in constant time (previously plain text)
App policy screens	Done (app build 6)	Settings › Policies opens Terms (in-app) and Refund/Return/Shipping (the website pages, in the browser)
Release signing fallback	Fixed (app build 6)	A release build now fails outright if android/key.properties is missing, instead of silently signing with the debug key

0c. Hardening found while fixing the above (not in the original findings)

Item	What changed
Refresh tokens	Stored as sha-256 instead of plain text (a database leak no longer hands out live sessions); legacy plain-text rows still work
Revoked Firebase sessions	verifyIdToken now checks revocation — a signed-out Firebase session can no longer be replayed against /auth/firebase-verify or the delete-account flow
Input limits	payment_method restricted to the 6 real options; product/user list sizes capped (100-1000 depending on the endpoint) so a large ?limit= can no longer return the whole catalogue; review rating must be an integer 1-5 with length limits; avatar_url must look like an uploaded https link; notification-preference keys validated; address set-default checks ownership before clearing the current default
Coupon race	A one-per-customer coupon is now re-checked under the same database lock as the usage-limit check, closing a narrow window where two simultaneous orders could both use it
Admin change history	New Settings › Security › "Recent admin changes" log — every admin/staff action (who, what, when) is recorded automatically. Verified live with 25+ real actions from the regression run
Access logs	Request logs now mask ?token=?key=?secret= values (the Delhivery webhook accepts a query-string token) and are more detailed in production
JSON body limit	10 MB › 2 MB (uploads go through multipart, not JSON)
Privacy policy	App and website now explain where to delete an account and that order records are kept (without the customer's name) for 6 years for GST, as Indian law requires

Full regression after every change: all customer test suites pass, admin suites pass except the 2 known Cloudinary-not-configured-locally items and 2 other pre-existing, unrelated items (a staging label-endpoint flake, an admin-tab-switch quirk); Delhivery staging lifecycle 48/48; payment-expiry 12/12; 493 responsive checks with 0 overflow and 0 script errors; 2,649-element tap audit with 0 blocked.

App to upload: FinalApp/ChillFi-v1.0.3-build6-release.aab (versionCode 6, same upload key as builds 4 and 5, rebuilt to include the Policies screen and privacy-policy text). Upload this file.

Contents

1. Readiness scorecard
2. What was analysed and how
3. Must-fix before real customers (developer)
4. Go-live runbook — the 6 owner steps, in order
5. Step 1 — Real contact details
6. Step 2 — GSTIN and tax invoices
7. Step 3 — Delhivery live
8. Step 4 — Confirm COD with Delhivery
9. Step 5 — PhonePe live
10. Step 6 — Remove test logins
11. Go-live day smoke test
12. Live production state (measured)
13. Security review
14. Payments, orders and money
15. Shipping and delivery
16. Login and accounts
17. Android app release
18. iOS
19. Website: performance, SEO, accessibility
20. Infrastructure, backups and monitoring
21. Email and domain
22. Quality evidence
23. Risk register
24. First 24 hours / first week after launch
25. Appendix — file references for the developer

1. Readiness scorecard

Area	Status	Evidence / what is left
Core shopping (browse, search, cart, checkout, orders, tracking)	Ready	438 of 463 QA cases pass, 0 fail; full regression green on 25 Sep; 124 defects fixed
Cash on Delivery orders	Ready	Works end-to-end today; live Delhivery COD must be confirmed (step 4)
Online payment (PhonePe)	Must fix	Return-page bug (F1) + webhook hardening (F7); then owner keys (step 5). Real PhonePe never tested with a live merchant
Shipping (Delhivery)	Owner step	48/48 staging lifecycle checks; switch to production + pre-switch clean-up (step 3)
Real OTP login on the Play build	Verify	Only test numbers were ever used. SHA fingerprints not registered in Firebase (F4). Test with a real SIM before launch
Test logins / backdoors	Must fix	Backend test phone 9876543210 › 123456 works on production (F2); Firebase test numbers (step 6)
Account deletion (Play policy)	Must fix	App has no in-app "Delete account" (F3); website delete page uses an OTP path that may not send SMS (F5)
GST invoices	Owner step	Built and tested; waiting for real GSTIN (step 2)
Contact details and support email	Owner step	Test values live; help@chillfi.in cannot receive mail — domain has no MX records (section 21)
Security	Ready	0 SQL-injection paths, server-side prices, credential encryption, OTP-only admin; 5 high dependency advisories to patch (F6)
Infrastructure / backups	Ready	Health 200 in 0.24 s, TLS valid to 5 Nov 2026, pm2 auto-restart, nightly verified backups; no off-server copy (R)
Monitoring	Owner step	Health endpoint ready; external uptime monitor not yet created
Website performance / SEO	Recommended	No gzip (906 KB script sent uncompressed), robots.txt/sitemap missing, meta tags only via JS
Android release	Ready	1.0.3 build 5 signed with the upload key; upload to Play + force update; voice search on Android 11+ to verify
iOS	Not in scope	Runs in the simulator; not publishable yet (no Firebase iOS config / push setup)
Code backup	Recommended	GitHub copy is from 6 Jun 2026 — 55 commits (all QA work) not pushed

2. What was analysed and how

- **Live production, read-only** (25 Sep 16:06 UTC): health, public app-config, TLS certificate, redirects, security headers, response times, compression, robots/sitemap, DNS (A, MX, SPF, DMARC), unauthenticated access to admin/payment endpoints, and a scan of the shipped JavaScript bundle for secrets. No production data was read or changed.
- **Code, line by line**: every go-live switch traced through backend, website and app (what each admin field does, which URL the server calls, what customers see before/after, how to roll back).
- **Security audit**: authentication, tokens, OTP, role checks, rate limits, CORS, input validation, SQL, uploads, webhooks, error handling, logging, credential encryption, secrets in git.
- **Tooling**: npm audit (backend + website production dependencies), Flutter analyzer, TypeScript compiler, git history, Android merged manifest, signing certificate of the release bundle.
- **Evidence from testing**: 463 QA cases, 16 browser suites, Delhivery staging lifecycle, payment-expiry test, 493 responsive checks, 1,758-element tap audit, Android emulator (Pixel 9 + small phone) and iPhone 17 simulator.

Limits of this analysis: the production server's private configuration (.env) and database were not opened. Items that depend on them are marked **Verify** with the exact check to run. No real payment, real shipment or real SMS was made.

3. Must-fix before real customers (developer)

Each item was confirmed in the code. None is visible during client testing because online payment is off and only test numbers are used — which is exactly why they must be fixed before switching to live.

#	Problem	Why it matters	Fix	Effort
F1	PhonePe return page: the payment request sends redirectUrl /api/payment/callback without the transaction id; in REDIRECT mode PhonePe returns without it, so the server sends the customer to "Order failed — Missing transaction ID".	Every successful website payment would show "failed" although the order is Paid (webhook). Customers may pay twice or complain.	Put the id in the URL: /api/payment/callback?merchantTransactionId=<id>; show a "confirming payment" page that polls verify.	1 h + UAT test
F2	Backend test login: phone 9876543210 always accepts OTP 123456 via /api/auth/send-otp + verify-otp; not limited to development.	If that user exists on production (QA used it), anyone can sign in as it — or register it.	Only allow TEST_PHONES when NODE_ENV=development; delete/disable that user on production.	30 min
F3	No account deletion inside the app (Play and Apple policy for apps with sign-up). Backend endpoint DELETE /api/profile/account exists.	Play review can reject the update or the listing.	Add Account › Settings › "Delete account" (confirm dialog › API › sign out).	2–3 h
F4	Firestore phone auth on the release build: google-services.json has no Android SHA fingerprints.	Real SMS OTP on the Play-signed app may fail or fall back to a browser captcha. Test numbers hide this.	Add SHA-1 + SHA-256 of the upload key AND the Play App Signing key in Firestore › Project settings; enable Play Integrity; re-download google-services.json; rebuild.	30 min + real phone test
F5	Website Delete Account page uses the backend OTP path (/auth/send-otp). The default provider "firebase" needs a captcha token the server never has — SMS likely never arrives.	The public deletion URL required by Play may not work.	Switch the page to the same Firebase sign-in the Login page uses, then call request-delete with the Firebase token.	2 h
F6	Dependency advisories: backend production deps 5 high (multer DoS, nodemailer, fast-xml-parser, ip-address, brace-expansion) + 9 moderate; website 2 moderate (react-router).	Known public vulnerabilities; multer is used for uploads.	npm audit fix (non-breaking) on both, run the regression, deploy.	1–2 h
F7	PhonePe webhook when keys are missing: the expected signature becomes sha256(payload+"null").	Only matters if the salt key is ever empty, but then a forged "paid" webhook would be accepted.	Refuse the webhook (503) when PhonePe is not fully configured; also compare the paid amount with the order.	30 min

Should fix soon (not launch blockers)

Item	Detail
Voice search on Android 11+	Manifest lacks the <queries> entry for android.speech.RecognitionService — the mic may not start on real phones. Verify on a device; add the entry.
Unused biometric permission	local_auth is in pubspec but never used › USE_BIOMETRIC/USE_FINGERPRINT in the manifest and a Play Data-safety question. Remove the package.
Settings encryption key	Stored gateway secrets are encrypted with a key derived from JWT_SECRET unless SETTINGS_ENCRYPTION_KEY is set. Set a separate key on the server before entering live keys (changing it later makes stored keys unreadable).

Item	Detail
Admin session	The 30-minute admin timeout is enforced in the browser only; tokens live 7 days. Consider shorter access tokens for staff.
Rate-limit bypass (verify)	If port 5000 is reachable from the internet, X-Forwarded-For can be spoofed. Confirm the EC2 security group only exposes 22/80/443.
OTP generator	Uses Math.random — switch to crypto.randomInt (backend OTP path only).
App policy screens	App has Privacy and Terms but no Refund/Return/Shipping pages — link them to the website pages.
Release signing fallback	If android/key.properties is missing a release build silently uses the debug key — make the build fail instead.

4. Go-live runbook — the 6 owner steps, in order

Do these **after the client finishes testing** and **after** the must-fix list in section 3 is deployed. The order matters: low-risk visible changes first, money last, test logins removed at the very end. Everything except step 6 is done in **chillfi.in/admin › Settings**; the **Go-Live** tab shows each item's live status with a "Fix" button.

Step	What	Where	Time	Risk
0	Preparation (day before): developer fixes deployed; server .env checked; Firebase SHA added; Delhivery test orders cleaned	Developer + Delhivery	½ day	Low
1	Real phone, email, WhatsApp, address	Settings › Store Info	5 min	None
2	Real GSTIN + legal name/address, then invoices ON	Settings › Store Info	10 min	Low
3	Delhivery live token + pickup name, environment = production	Settings › API Keys › Shipping	20 min	Medium — real, chargeable shipments
4	Confirm COD on the live Delhivery account (or switch COD off)	Delhivery + Settings › Shipping	1 call	Medium
5	PhonePe live Merchant ID + Salt Key, environment = PRODUCTION, ₹1 test	Settings › API Keys › Payment Gateway	30 min	High — real money
6	Remove Firebase test numbers + backend test login	Firebase console + developer	10 min	Low
+	Upload app 1.0.3 build 5 to Play, then Force Update ON (min 1.0.3)	Play Console, Settings › Store Info	1–3 days review	Low

Step 0 — preparation checklist (day before)

1. Developer: deploy fixes F1–F7 (section 3) and run the regression.
2. Developer: on the server confirm **NODE_ENV=production**, **APP_BASE_URL=https://chillfi.in**, **WEBSITE_URL=https://chillfi.in** (PhonePe return and webhook URLs are built from these), a separate **SETTINGS_ENCRYPTION_KEY**, and that **PHONEPE_ENV** in .env is not "PROD" (a stale Railway file shows PROD — the admin value wins only when it is set).
3. Developer: Firebase console › Project settings › Android app com.ecom.chillfi › add SHA-1 and SHA-256 of the **upload key** and of the **Play App Signing key** (Play Console › Setup › App integrity). Re-download google-services.json, rebuild, and log in with a **real** SIM on a real phone.
4. Firebase console › Authentication › Settings › Authorized domains: chillfi.in and www.chillfi.in present (website OTP).
5. Admin › Orders: cancel every order that was shipped on Delhivery **staging** (once production is selected, staging AWBs can no longer be cancelled from admin), and review orders still "pending shipment" — see step 3.
6. Set up the uptime monitor (section 20) so you are alerted during the switch-over.
7. Tell customers nothing yet; keep maintenance mode OFF (the switch-over does not need downtime).

5. Step 1 — Real contact details

Where	chillfi.in/admin › Settings › Store Info › Save
Before you start	The real support phone (10-digit Indian mobile), a WhatsApp number (optional), a support email that can receive mail (see section 21 — help@chillfi.in currently cannot), and the registered business address.

Do this

1. Open Settings › Store Info.
2. Replace Phone Number (now +91 98765 43210, a sample), Support Email, Store Email, WhatsApp Number and Store Address (now "123, Tech Park, Whitefield...", a sample).
3. Press Save.

What the system does

- The public /api/app-config "contact" block updates within ~30 s; tel: and wa.me links are built automatically from a 10-digit number.
- Website Contact, Support, Privacy/Terms/Refund/Return/Shipping and Delete-account pages, and the app Help & Support screen read these values. Tax invoices print the phone and email.

How to verify

1. Go-Live tab: "Real contact details" turns Done (it checks the phone is not the sample and the address is not "Tech Park, Whitefield").
2. Open chillfi.in/contact and the app › Account › Help & Support: new number and email show; tap Call / WhatsApp / Email and confirm they open correctly.
3. Send an email to the support address from a personal account and confirm it arrives.

Roll back

- Type the previous values back and Save.

Watch out for

- There is no format validation — a typo is published immediately. Check each value twice.
- The website does not show the address on the Contact page yet (only phone/email/WhatsApp).

6. Step 2 — GSTIN and tax invoices

Where	Settings › Store Info › GST Number, Store Name, Store Address › Save; then toggle "Issue GST Tax Invoices" › Save
Before you start	Your GST registration certificate: 15-character GSTIN, exact legal/trade name and principal place of business. Optional: HSN codes for each product (Admin › Products › edit › HSN Code, 4/6/8 digits).

Do this

1. Enter the GSTIN exactly (capital letters). Enter Store Name and Store Address exactly as on the certificate. Save.
2. Confirm GST Rate (%) — prices are GST-inclusive at this rate (default 18).
3. Turn on "Issue GST Tax Invoices" and Save. The server refuses if the GSTIN format is invalid.
4. Optionally add HSN codes to products (invoices show "—" when missing).

What the system does

- Seller state = first two digits of the GSTIN. Buyer in the same state › CGST + SGST; other states › IGST.
- Invoice numbers: CF/<financial year>/000001 upward, per financial year (April start). A number is assigned when an invoice is first generated.
- Invoices are offered only for orders that are Shipped or Delivered (not cancelled): website order page, app order details, admin order view.

How to verify

1. Go-Live tab: "GST tax invoices" turns Done (it also rejects the sample GSTIN 29AABCU9603RIZM, which otherwise passes the format check).
2. Admin › Orders › open a Delivered order › Invoice: check your name, address, GSTIN, tax split and amount in words.
3. Ask your accountant to review one sample invoice before real sales.

Roll back

- Turn "Issue GST Tax Invoices" off › customers see "Invoices are not enabled yet". Already-issued numbers are kept.

Watch out for

- Once real invoices are issued, do not change the GSTIN or numbering mid-year without your accountant.
- Buyer state is read from the address text; unusual state spellings default to intra-state (CGST+SGST).

7. Step 3 — Delhivery live shipping

Where	Settings › API Keys › Shipping (Delhivery) — each field is saved on its own; the status panel above the fields shows what is missing, the webhook URL, last webhook, and Test / Sync / Pickup buttons
Before you start	Live API token from Delhivery, the exact registered pickup (warehouse) name, Delhivery client name and seller GSTIN. A webhook secret you choose (long random text). Delhivery account approved for live shipping.

Do this

1. **Clean up first:** Admin › Orders. Any order that is Processing/Paid or COD with shipment "pending" or "failed" will be **booked as a real shipment within 30 minutes** of switching — however old. Cancel test orders now, or set "Auto-ship" = false first and ship manually.
2. Cancel orders already shipped on staging (they cannot be cancelled from admin after the switch).
3. Enter DELHIVERY_TOKEN (live), DELHIVERY_PICKUP_LOCATION (exact name), DELHIVERY_CLIENT_NAME, DELHIVERY_SELLER_GST, default weight (grams), pickup time and cut-off.
4. Enter DELHIVERY_WEBHOOK_SECRET, then send Delhivery the webhook: URL **<https://chillfi.in/api/shipping/delhivery/webhook>**, header **Authorization: Bearer <your secret>** (draft email: QA/DELHIVERY_REQUEST_EMAIL.md).
5. Set Environment = production and confirm the warning ("REAL, chargeable shipments").
6. Press **Test** in the status panel, then place one real COD order to your own address.

What the system does

- COD orders are booked at order time; prepaid orders when payment succeeds. A pickup is booked the same day before the cut-off, otherwise next working day (Sundays skipped).
- Every 30 minutes (one server process) it retries failed bookings (max 5), syncs tracking, books pickups and expires unpaid online orders.
- Webhook scans update the order (Shipped, Out for delivery, Delivered, RTO) and notify the customer; Delivered COD orders are marked Paid.

How to verify

1. Go-Live tab: "Delhivery live shipping" = Done ("Live — pickup location ...").
2. Your test order gets an AWB within a minute; the label downloads (Admin › Orders › Label); the AWB is visible in Delhivery One.
3. Status panel shows "last webhook received" after the first scan.
4. Cancel the test order before pickup (Admin › Orders › Cancel) and confirm it disappears in Delhivery.

Roll back

- Environment = staging (instant) or Auto-ship = false. Production AWBs stop syncing while on staging — switch back promptly.

Watch out for

- Wrong pickup name › every booking fails ("pickup location not found"); the error is shown on the order.
- Staging account has COD disabled — do not judge live COD from staging.
- Serviceability answers are cached 6 h per pincode; restart the API after switching for fresh results.

8. Step 4 — Confirm COD with Delhivery

Where	Delhivery account manager / Delhivery One; then Settings › Shipping › "COD Available"
Before you start	Your live Delhivery client code; COD remittance bank details submitted to Delhivery.

Do this

1. Ask Delhivery to confirm in writing that **COD is enabled** on the live client and the COD limit per parcel.
2. If COD is not enabled: Settings › Shipping › turn "COD Available" OFF › Save (checkout then offers online payment only — only do this after step 5 works).
3. Optionally restrict COD by pincode prefix with Shipping Rules (COD available on/off, fee, delivery days).

What the system does

- Checkout combines three things: the store switch, the pincode rule (longest prefix wins) and Delhivery's own COD flag for the pincode.
- If Delhivery rejects a COD parcel the admin sees "Cash on Delivery isn't enabled on this Delhivery account..." and the order is retried up to 5 times.

How to verify

1. Place one COD order to a serviceable pincode › AWB created (no COD error).
2. With COD off: website badge "Currently unavailable", app subtitle "Currently unavailable", API refuses COD orders.

Roll back

- Toggle "COD Available" back.

Watch out for

- The Go-Live "Cash on Delivery" item is always shown as done — it cannot know Delhivery's answer; this step is manual.
- Turning COD off while online payment is still in test mode leaves customers with no way to pay.

9. Step 5 — PhonePe live (real money)

Where	Settings › API Keys › Payment Gateway
Before you start	Must-fix F1 and F7 deployed. PhonePe business account approved for live, with the Merchant ID, Salt Key and Salt Index (this code uses the PhonePe PG v1 salt-key API — if PhonePe gives you a v2 client-id/secret instead, the developer must add v2 first). Refund process agreed (below).

Do this

1. Enter PhonePe Merchant ID, Salt Key and Salt Index (each saved on its own; the key is stored encrypted and only the last 4 characters are shown).
2. Set PhonePe Environment = PRODUCTION and confirm the warning.
3. If the PhonePe dashboard asks for URLs: website/domain <https://chillfi.in>; callback/webhook <https://chillfi.in/api/payment/webhook> (the server also sends these with every payment).
4. Within 30 seconds checkout shows online payment on the website and in the app.
5. Real test: place a ₹1–10 order online from the website and from the app with your own UPI/card.
6. Cancel it from Admin › Orders; a refund request opens automatically › refund it in the PhonePe dashboard › Admin › Refunds › mark Refunded.

What the system does

- Customer pays on PhonePe's page › PhonePe calls the webhook (signature checked) › order becomes Paid › confirmation + (if Delhivery live) automatic shipment.
- The app also verifies the payment when the customer returns to it.
- Unpaid online orders older than 2 hours are checked with PhonePe: completed › Paid; failed › cancelled, stock and coupon released.
- **Refunds are manual:** the system opens a refund request (customer cancel, admin cancel, or payment arriving on a cancelled order); money is returned from the PhonePe dashboard.

How to verify

1. Go-Live tab: "Online payments live (PhonePe)" = Done ("Live — real payments accepted").
2. Website test: after paying you land on the order success page (not "Order failed").
3. Admin › Orders: test order Payment = Paid, payment method PhonePe; server log line "[order] paid ... via phonepe-webhook".
4. Refund reaches your account; Admin › Refunds shows Refunded and the customer got the notification.

Roll back

- Set Environment back to UAT: online payment is hidden and refused immediately. Paid orders are unaffected; unpaid online orders are left untouched (clean up manually).

Watch out for

- Never test with large amounts. Keep the PhonePe dashboard open during the first day.
- If Delhivery is already live, a paid test order ships automatically — cancel it before pickup.
- Enter the live keys only after SETTINGS_ENCRYPTION_KEY is set on the server (step 0).

10. Step 6 — Remove test logins

Where	Firebase console › Authentication › Sign-in method › Phone › "Phone numbers for testing"; developer for the backend test phone
Before you start	Client testing finished; step 0 real-SIM login worked (otherwise removing test numbers can lock everyone out of testing).

Do this

1. Firebase: delete +91 90000 00001, +91 98765 43210, +91 90562 24993, +91 83606 91637 (all test numbers) › Save.
2. Developer: deploy fix F2 (backend test phone 9876543210 only in development) and disable/delete the 9876543210 user on production.
3. Developer: remove the test customer accounts used in QA (e.g. "DLV-TEST Customer", "QA Person") or anonymise them via account deletion.
4. Optional: Firebase › Authentication › Settings › SMS region policy = allow India only (limits SMS abuse/cost).

What the system does

- Test numbers no longer bypass SMS; every login needs a real OTP.

How to verify

1. Try +91 90000 00001 on the website and the app › no login with 123456.
2. Log in with a real number › OTP SMS arrives within ~30 s, login succeeds.

Roll back

- Re-add a test number in the Firebase console (only if needed for support).

Watch out for

- Do this last — after steps 1–5 are verified with real accounts.

11. Go-live day smoke test (30 minutes, after steps 1–6)

#	Check	Expected
1	https://chillfi.in/api/health	{"status":"ok","db":"ok"} in under 1 s
2	New customer sign-up with a real number (website and app)	OTP SMS, account created, lands on Home
3	Search, product page, add to cart, apply a coupon	Prices GST-inclusive; coupon total correct
4	Checkout with a serviceable pincode	COD and online options as configured; delivery estimate shown
5	Online ₹1 order (website and app)	Success page; order Paid; confirmation push/email
6	COD order	Order placed; Delhivery AWB within a minute
7	Admin: order list, label, invoice (after Shipped)	Label downloads; invoice shows your GSTIN
8	Cancel both test orders; refund the online one	Shipments cancelled in Delhivery; refund completed
9	Contact page, Help & Support in app	Real phone/email/WhatsApp open correctly
10	Delete-account page with a spare account	OTP arrives; account removed
11	Admin › Settings › Go-Live	All items Done except optional SMS
12	Uptime monitor	Shows "Up"; alert contact receives a test alert

12. Live production state (measured 25 Sep 2026, 16:06 UTC)

Check	Result	Status
API health	200 {"status":"ok","db":"ok"}, 0.24 s	Ready
Response times	Home page 0.22 s, product list API 0.27 s, home API 0.28 s	Ready
HTTPS	http › https 301; certificate Let's Encrypt, chillfi.in + www.chillfi.in, valid until 5 Nov 2026 (auto-renew)	Ready
www.chillfi.in	Serves the site directly (no redirect to chillfi.in) — duplicate URL for search engines	Recommended
Online payment	online_payment_available = false (test mode locked off) — expected until step 5	Owner step
Maintenance mode	off	Ready
Contact shown to customers	+91 98765 43210 / help@chillfi.in / "123, Tech Park, Whitefield..." — sample values	Owner step
Force update	off, minimum version 1.0.0 — turn on after build 5 is live on Play	Owner step
Pricing	GST-inclusive, rate 18%, free shipping above ₹999, max delivery 7 days	Ready
Admin API without login	401 "No token provided"	Ready
Security headers (API)	HSTS 1 year, nosniff, X-Frame-Options SAMEORIGIN	Ready
Security headers (web pages)	none (HSTS/nosniff/frame-options only on /api)	Recommended
Compression	no gzip on HTML or JS; main script 906 KB sent uncompressed	Recommended
robots.txt / sitemap.xml	return the app HTML (files do not exist)	Recommended
Secrets in the shipped JavaScript	only the Firebase web API key (public by design; restrict it to chillfi.in in Google Cloud)	Ready
DNS e-mail records	no MX, no SPF, no DMARC for chillfi.in	Must fix

13. Security review

Overall the application security is solid for launch once F2, F6 and F7 are done. Findings by area:

Area	Finding	Severity
SQL injection	All user input goes through parameterised queries; sort columns are whitelisted. No injectable query found.	Low (OK)
Prices / totals	Computed on the server with stock and coupon rows locked; quantity must be an integer 1...stock.	Low (OK)
Order access	Every order, invoice, tracking, cancel and refund lookup is scoped to the signed-in user.	Low (OK)
Admin access	All /api/admin routes need staff/admin; sensitive ones admin-only; admins cannot demote/block themselves.	Low (OK)
Admin sign-in	Phone OTP only (password login disabled); sign-ins logged with IP/device; 30-min idle sign-out (browser).	Low (OK)
Test login backdoor	Phone 9876543210 › OTP 123456 on production (F2).	High
Stored gateway keys	AES-256-GCM, masked in admin; key derived from JWT_SECRET unless SETTINGS_ENCRYPTION_KEY set.	Medium
PhonePe webhook	Signature compared in constant time; weak when salt key missing; amount not cross-checked (F7).	Medium
Delhivery webhook	Bearer secret, constant-time compare; 503 when not configured. Token also accepted in ?query (logged by request log).	Low
Tokens	Access 7 days, refresh 30 days rotated on use; refresh tokens stored unhashed; website keeps tokens in localStorage.	Medium
OTP (backend path)	Math.random generator; plain-text OTP storage; 5 attempts; 1/min + 5/hour per phone.	Low
Rate limiting	200 requests/min per IP; no tighter limit on login, coupon or contact form; verify port 5000 is not public.	Medium
CORS	Allows localhost origins and http://3.111.32.220 with credentials in production — tidy up.	Low
Uploads	Images only, 5 MB, memory storage, Cloudinary re-validates.	Low (OK)
Errors / logs	No stack traces or secrets to clients; friendly messages with reference id.	Low (OK)
Secrets in git	.env, keystore, key.properties, service account and .pem are ignored and not in history.	Low (OK)
Dependencies	Backend: 5 high + 9 moderate advisories; website: 2 moderate (F6).	High
Audit trail	Sign-ins are recorded; other admin actions (refunds, role changes, settings) only in server logs.	Low

14. Payments, orders and money

- **Pricing:** GST-inclusive — the displayed price is what the customer pays; GST is shown as "Includes GST". Charged total = displayed total (verified on website and app).
- **Safety net while in test mode:** on production the server refuses online orders and ignores any sandbox "success", so no order can be marked paid without real money.
- **Abandoned payments:** unpaid online orders are checked with PhonePe after 2 hours and cancelled only if PhonePe confirms non-payment (stock and coupon released). If PhonePe cannot be reached nothing is cancelled.
- **Late payment on a cancelled order** automatically opens a full refund request and informs the customer.
- **Refunds** are recorded in Admin › Refunds; the money itself is returned from the PhonePe dashboard (no refund API integration). Plan who does this daily.
- **Coupons** are re-validated at order time (expiry, minimum order, per-user use, usage limit).
- **COD:** store switch + per-pincode rules + Delhivery COD flag; delivered COD orders are marked Paid automatically.
- **Must fix:** F1 (return page) and F7 (webhook hardening) before step 5. Real PhonePe (even UAT) was never completed end-to-end because card entry needs a person — do the ₹1 test in step 5.

15. Shipping and delivery

- Delhivery staging lifecycle: 48/48 checks (create, AWB, pickup, tracking, delivered, RTO, cancel, webhooks, duplicate/out-of-order protection).
- Automatic booking: COD at order time, prepaid on payment; retries up to 5 times; tracking sync every 30 min; one process runs the scheduler (no double booking).
- Invalid address and COD-not-enabled errors are shown to the admin in plain words.
- Serviceability check at checkout; unknown results never block a customer.
- Owner step 3 includes a mandatory clean-up of pending/staging orders — the most likely go-live surprise.
- Package weight defaults to 500 g for every item unless set — set real weights to avoid Delhivery weight disputes.

16. Login and accounts

- Website and app sign in with Firebase phone OTP; the server verifies the Firebase token and issues its own session.
- **Verify:** real-SIM OTP on the Play-signed build after adding SHA fingerprints (F4). This has never been tested — only test numbers.
- Website OTP uses an invisible reCAPTCHA; authorised domains must include chillfi.in and www.chillfi.in.
- Sign-ups can be paused from admin; blocked users are rejected on every request.
- **Account deletion:** backend supports deletion (orders are anonymised; the shipping address on past orders is kept for tax records — say so in the Privacy Policy). App entry point missing (F3); website page likely not sending SMS (F5).
- Guest browsing is allowed; cart, wishlist, orders and addresses require an account (no guest checkout).

17. Android app release

Item	Value	Status
Package / name	com.ecom.chillfi / "ChillFi"	Ready
Version	1.0.3, build 5 (versionCode 5) — FinalApp/ChillFi-v1.0.3-build5-release.aab	Ready
Signing	Upload key, certificate SHA-256 50:5C:1D:A6:CE:E3:64:69... (same as build 4)	Ready
SDK	minSdk 24 (Android 7), targetSdk 36 — meets current Play requirement	Ready
Code shrinking	R8 minify + resource shrinking on	Ready
Network	HTTPS only (cleartext blocked), API https://chillfi.in/api	Ready
Permissions	Internet, notifications, microphone (voice search), biometric (unused — remove)	Verify
Account deletion in app	missing (F3)	Must fix
Play Data safety	Declare: phone number, name, email, address, purchase history, audio (voice search, not stored), device ID for push	Owner step
Store listing	Privacy policy URL https://chillfi.in/privacy-policy; deletion URL https://chillfi.in/delete-account (after F5)	Owner step
Force update	After build 5 is live: Store Info › Force Update ON, minimum 1.0.3 (1.0.2 shows GST added on top)	Owner step

18. iOS

The app runs on the iPhone 17 simulator (onboarding, login screens, tabs, swipe-back, empty states verified; minimum iOS 15). **Not publishable yet:** GoogleService-Info.plist missing (Firebase fails to start › OTP and push unavailable), no push entitlement / background mode, no URL scheme for phone-auth reCAPTCHA, no in-app account deletion, display name "Chillfi". Needed only if an App Store release is planned: Apple Developer account, APNs key uploaded to Firebase, and the items above.

19. Website: performance, SEO, accessibility

Topic	Finding	Action
Responsive	493 page × width checks (320–1920 px): 0 overflow, 0 JS errors; 1,758 interactive elements, 0 blocked	none
Accessibility	Visible keyboard focus ring, one h1 per page, reduced-motion respected, labelled controls	none
Speed (server)	First byte 0.2 s from India-region server	none
Speed (download)	No gzip/brotli; single 906 KB JavaScript file (admin included)	Enable gzip in nginx (about 70% smaller); later split admin into its own chunk
Caching	Hashed assets cached 1 year (immutable); HTML not cached	none
SEO basics	Title present; description/Open Graph tags added only by JavaScript	Put default description + OG tags in index.html
robots.txt / sitemap	Missing (URLs return the app page)	Add robots.txt and a sitemap (static pages + products)
Duplicate host	www.chillfi.in serves the same site	301 www › chillfi.in in nginx
Security headers	Only on /api	Add HSTS, nosniff, frame-options, referrer-policy to nginx for all pages
Legal pages	Privacy, Terms, Refund, Return, Shipping, Delete-account present	Update contact/address after step 1

20. Infrastructure, backups and monitoring

- **Server:** AWS EC2 (Mumbai region IP 3.111.32.220), ~1 GB RAM, Node 22, pm2 with 2 API processes, auto-start on reboot, log rotation 10 MB × 7; nginx with HTTPS.
- **Deploys:** scripted, dry-run first, automatic backup of backend and website before every deploy, health check after.
- **Database backups:** nightly 02:30 IST, 7 daily + 6 monthly, each verified readable; restore check compares row counts. **Gap:** copies live on the same server — add an EBS snapshot policy or S3 copy.
- **Monitoring:** /api/health checks API + database. **Owner:** create an UptimeRobot (free) keyword monitor on <https://chillfi.in/api/health> for "ok", 5-minute interval, alerts to email + phone app.
- **TLS:** Let's Encrypt valid to 5 Nov 2026; confirm the renewal timer once (sudo certbot renew --dry-run).
- **Capacity:** fine for launch. Move to t3.small (2 GB) when traffic grows — first confirm the IP is an Elastic IP.
- **Code backup:** GitHub (thesonushah1-dot/chillfi) last updated 6 Jun 2026; 55 newer commits exist only locally and on the server — push them (with your OK).

21. Email and domain

- **chillfi.in has no MX record** — mail to help@chillfi.in (shown on the website, app, invoices and policies) cannot be delivered. Either set up mailboxes (Zoho Mail / Google Workspace: add their MX records) or show an address that works today.
- **No SPF or DMARC** — once order emails are sent from @chillfi.in they are likely to land in spam. Add the SPF and DKIM records your email provider gives you, and a DMARC record (start with p=none).
- Order emails are built and waiting: Settings › API Keys › Email (SMTP) › "Send test email".
- SMS order updates (optional) need a DLT-approved MSG91 template.

22. Quality evidence

Area	Cases	Pass	Fail	Blocked	N/A
Mobile app	231	212	0	4	15
Website	136	132	0	4	0
Admin	96	94	0	2	0
Total	463	438	0	10	15

- 124 defects found (11 critical, 46 high, 41 medium, 26 low) — all fixed, re-tested and deployed.
- The 10 blocked cases need a person or a key: PhonePe card entry (3), website reCAPTCHA OTP (3), online test payment (1), Cloudinary uploads locally (3).
- Final regression 25 Sep: all customer suites pass; admin suites pass except the 2 Cloudinary upload checks (keys only on production) and 1 known test-harness limitation.
- UI consistency pass: one design system (type, spacing, radius, motion), shared back button, empty states and page transitions on app and website; verified on Pixel 9, a 360×640 phone and iPhone 17.
- Not covered by testing: real SMS OTP, real PhonePe money, live Delhivery, real-device push, iOS release.

23. Risk register

Risk	Likelihood	Impact	Mitigation
Customer sees "payment failed" after paying	High (certain without F1)	High	Fix F1; ₹1 test in step 5
Real OTP fails on the Play build	Medium	High (no new sign-ups)	F4 + real-SIM test before launch
Old test orders booked as real shipments	Medium	Medium (courier charges)	Step 3 clean-up / auto-ship off first
Test login used by someone else	Low-Medium	High	F2 + step 6
Play rejects update (no in-app deletion)	Medium	Medium (delay)	F3 before uploading
Support emails never arrive	High (certain today)	Medium	MX + mailbox for the support address
Order emails in spam	High without SPF/DKIM	Low-Medium	DNS records from mail provider
COD not enabled on live Delhivery	Unknown	Medium	Step 4 written confirmation
Refunds delayed	Medium	Medium (complaints)	Daily refund routine; PhonePe dashboard access
Server loss (disk/instance)	Low	High	Off-server backup copy + GitHub push
Outage unnoticed	Medium	Medium	UptimeRobot alerts
Known dependency vulnerability exploited	Low	Medium	F6
Wrong GST details on invoices	Low	Medium	Accountant reviews a sample (step 2)
Old app (1.0.2) shows GST on top	Certain until force update	Low	Force update after build 5 is live
Traffic spike on 1 GB server	Low at launch	Medium	Watch memory; resize to t3.small

24. First 24 hours / first week after launch

First 24 hours

- Keep Admin › Settings › Go-Live and Admin › Orders open; check new orders every hour.
- Every online order: Payment = Paid within a minute; any "Pending" online order older than 30 minutes › check it in the PhonePe dashboard.
- Every order: AWB present; any "shipment failed" › read the reason on the order (address, pincode, COD).
- Watch the uptime monitor and the admin alert bell (failed shipments, refunds, messages, low stock).
- Answer support messages the same day (Admin › Messages).

First week

- Daily: refunds processed, pickups happened, COD remittance from Delhivery reconciled.
- Check that nightly backups are fresh (Go-Live tab "Nightly database backup").
- Review app-store reviews and crash reports (Play Console › Android vitals).
- Turn on Force Update once most users are on 1.0.3.
- Plan the recommended items: gzip, robots/sitemap, security headers, off-server backup, iOS if wanted.

25. Appendix — file references for the developer

Item	Where in the code
F1 PhonePe return URL	backend/src/controllers/paymentController.js:35 (redirectUrl) and :236-242 (callback reads query)
F2 test phone	backend/src/utls/otp.js:8 and :128-147
F3 app account deletion	backend/src/routes/profile.js:22 (DELETE /api/profile/account); add UI under lib/features/profile/settings_screen.dart
F4 Firebase Android config	android/app/google-services.json (oauth_client empty)
F5 website delete page	web/website/pages/DeleteAccount/index.tsx:21,37; backend/src/utls/otp.js:62-92
F6 dependencies	backend/package.json, web/website/package.json (npm audit --omit=dev)
F7 webhook hardening	backend/src/utls/phonepe.js:45-46; backend/src/controllers/paymentController.js:183-233
PhonePe environments	backend/src/utls/phonepe.js:15-57
Delhivery environments / scheduler	backend/src/utls/delhivery.js:16-58; backend/src/services/shipmentService.js:338-380
Go-Live checklist	backend/src/controllers/adminController.js:258-310; web/website/components/admin/GoLiveChecklist.tsx
Invoices / GSTIN	backend/src/utls/invoice.js:9,54-123
Settings encryption	backend/src/utls/settings.js:13-41
Voice search manifest	android/app/src/main/AndroidManifest.xml (queries block)
Runbooks	QA/OPS_RUNBOOK.md, QA/DELHIVERY_GO_LIVE.md, QA/UI_SYSTEM.md